

Platform, Security and Compliance

A plain-language response to ASTRA's review of the Procurement Platform proposal

From	BKS Solutions
To	ASTRA — Procurement, Engineering, IT and Commercial review
Date	19 August 2026
Subject	Response to the eight queries raised on our proposal, and to ASTRA's request for the security and compliance position of the AI technology used
Status	For discussion. Commercial figures marked <i>indicative</i> are subject to the commercial schedule.

How to read this document

ASTRA raised eight queries on our proposal, and asked separately for a clear account of the security and compliance position of the artificial-intelligence technology the platform uses. This document answers both in one place.

It is written for a mixed audience — procurement, engineering, IT and commercial — so it avoids technical vocabulary wherever plain English will do. Where a technical term is unavoidable, it is explained in the sentence that uses it, and again in the glossary at Appendix E.

Three things are worth saying about the posture of this document before you read it.

It is written to be checked, not to reassure. Every capability described as built can be demonstrated during the proof of concept. Every capability that is *not* built is named in the same paragraph as the ones that are, rather than in a footnote.

Everything that is missing appears in one list. Part Three is a single consolidated register of every limitation named anywhere in this document. A proposal that lists only strengths is not a proposal you can plan against.

Where we cannot verify something ourselves, we say whose word it rests on. Part Two describes security certifications held by Amazon, Anthropic and OpenAI. Those are *their* certifications, not ours, and we do not present them as ours. We say exactly where BKS's own responsibility begins.

Summary — the eight queries at a glance

#	What ASTRA asked	Our position
1	This looks like a document extraction and comparison portal, not a complete procurement solution	Partly accepted. Our deck under-sold the platform — the full enquiry-to-award lifecycle is built. But it is not an end-to-end purchase-to-payment suite, and we will not claim it is.
2	The proposal mixes subscription software with on-premise deployment. Where does our data and AI processing actually sit?	Accepted. We presented two different delivery models as if they were one. Three clean options are set out in §2.
3	The AI architecture, data residency, running costs, model dependency and security controls are undefined	Accepted. Answered in §3 and Part Two.

#	What ASTRA asked	Our position
4	The customisation cost has no deliverables schedule behind it	Accepted. A fixed-scope matrix is at Appendix C.
5	Ten named users is impractical across four departments	Accepted. Three seat structures offered in \$5.
6	The engineering AI scope is too broad	Accepted — withdrawn from Phase 1.
7	Who owns the solution, the source code, the data and the AI prompts, and what happens if BKS stops supporting it?	Answerable in full, and we regard our answers as contractual.
8	Run a measured proof of concept before committing	Agreed — this is the right next step, and your framing of it is better than ours.

Part One — Your eight queries, answered

1. "Mainly an AI extraction and comparison portal rather than a complete procurement solution"

What is fair in this

The pitch deck we sent describes seven steps, and every one of them belongs to the bid-comparison engine: take in the documents, recognise what each one is, work out which revision supersedes which, read the contents, file the findings, measure them against the requirement, and support the decision. Read on its own, that deck supports exactly the conclusion you reached. That is a failure of our document, not a misreading on your side.

What the deck left out

The platform is two systems, not one. Alongside the comparison engine there is a complete enquiry-to-award workflow, built and under test, and reachable through 47 separate service endpoints.

Capability	State	What it means in practice
Eight-stage RFQ lifecycle	Built	Shortlisting → Enquiry Issued → Clarifications → Bids Received → Evaluation → Negotiation → Award → PO Issued, with fixed process codes. The system refuses any move between stages that is not explicitly permitted, and the documented recoveries — retender, renegotiate — are permitted deliberately rather than by accident.
Project → line item → RFQ structure	Built	An enquiry covers named line items inside a project. Nothing can be deleted while something live still refers to it, and the refusal names what is blocking it.
Vendor registry	Built	Organisation-wide, roughly 1,300 vendors loaded from a real ADNOC Approved Vendor List export, plus an Astra-approved subset. Searchable by discipline, product group and approval.
Vendor eligibility and prequalification	Built	Suitability is worked out from prequalification status, expiry date and scope fit. Expiry is calculated at the moment you look, not by an overnight job — so the register cannot quietly go stale.
Shortlisting and client approval	Built	Inviting a vendor is an attributed act with a name against it. Inviting a vendor who is blocked requires a written reason, recorded. Client approval is read live from the approved vendor list, so correcting one row in the registry corrects every shortlist that refers to it.
Draft shortlists per line item	Built	A buyer assembles candidates before any enquiry exists. When the enquiry is raised, the draft becomes invitations automatically — and any vendor skipped is reported by name with the reason.
Issuing the enquiry by email	Built	The platform sends the enquiry package to shortlisted vendors, one message per vendor with only that vendor's copy of the documents attached. See the note below.
Returnables checklist	Built	Nine fixed returnables travel with every enquiry, so what a bidder must send back is stated in the mail itself, in the same words the evaluation later checks against.
Clarification rounds	Built	Numbered queries, with Open / Answered / Withdrawn worked out from the record rather than typed in. An answer withheld from the rest of the shortlist requires a recorded reason.
Addenda	Built	The single controlled route to change a frozen enquiry package, issuing at a new revision, with safeguards against two people editing at once.
Enquiry and bid document management	Built	One store holds both the documents you issued and the documents bidders returned, filed by content so the same file uploaded twice is stored once.
Technical bid evaluation and vendor document register	Built (service side)	The underlying services are built and tested; some screens were deliberately simplified — see Part Three.

Capability	State	What it means in practice
Discipline vocabulary	Built	A controlled list of disciplines joined to your own product-group taxonomy, so scope matching resolves against the real register rather than free text.
Bid comparison engine	Built	The seven steps in the deck.
Cost estimation	Built (command line only)	A separate costing-sheet tool. Not reachable from the web application today.

A correction to our 18 August response. That document stated that nothing in the platform sends mail, and listed it as a gap. That is no longer true and has not been true for some weeks: outbound enquiry mail is built, covered by 38 automated tests, and has issued real enquiries over a live mail server. We are correcting it here rather than letting a stale limitation stand — and noting the one thing that does remain a configuration task, which is pointing it at ASTRA's own mail infrastructure.

Two details of that feature matter commercially. Each vendor receives their **own** message — never one message addressed to the whole shortlist, which would tell every bidder who their competitors are and would cost you the tender. And only the documents *you* issued are ever attached; a document a bidder returned can never travel to a competitor.

What it genuinely is not

Stated directly, so that nobody plans against something that does not exist:

- **It is not a purchase-to-payment suite.** There is no purchase-order issue into an ERP system, no goods receipt, no invoice matching, no payment, no contract lifecycle management, no supplier scorecarding, no reverse auction, and no catalogue purchasing.
- **No ERP integration is built.** Connecting to SAP, Oracle or anything else is a defined, priced piece of work — not a shipped feature.

What we propose

We will re-issue the proposal describing the scope as "**enquiry management and bid evaluation**" rather than as a comparison portal, with the boundary above printed in the document rather than discovered in review. If ASTRA's real requirement is purchase-to-payment, we would much rather establish that now than in month four.

2. Subscription software or on-premise? Where the data and the AI processing actually sit

Accepted without qualification

Our proposal used subscription language — seats, credits, plans — alongside security language about deploying inside your own perimeter. Those are two different delivery models and we presented them as though they were one thing. The confusion is ours.

The three models, stated separately

	A — BKS-managed, dedicated to ASTRA	B — Running inside ASTRA's own cloud	C — True on-premise
Who owns the infrastructure	BKS	ASTRA	ASTRA

	A — BKS-managed, dedicated to ASTRA	B — Running inside ASTRA's own cloud	C — True on-premise
Where it runs	BKS's cloud account, in a region ASTRA approves	ASTRA's own cloud account and region	ASTRA's own data centre
Where your documents are stored	BKS-controlled encrypted storage	ASTRA-controlled; ASTRA holds the encryption keys	ASTRA storage
Where the AI runs	Amazon Bedrock in-region, or a provider API	Amazon Bedrock inside ASTRA's own account and region	A self-hosted open model on your hardware
Does document text leave ASTRA's boundary?	Yes — to BKS's account	No	No
Does anything leave the country?	No — the region is pinned	No	No
Commercial shape	Subscription	Subscription, plus ASTRA pays its own cloud bill	Licence plus support
Extraction accuracy	As measured	As measured — identical models	Unmeasured. Expect lower.
Our recommendation	For the proof of concept	For production	Only if policy forbids B

Our recommendation, and the reason

Model B for production; Model A for the proof of concept.

Model B answers your question in the strongest form available. With Amazon Bedrock — Amazon's own managed AI service — running inside ASTRA's cloud account in a region ASTRA approves, **document content never leaves ASTRA's boundary and never leaves the region**. There is no outbound call to any AI vendor's public service, no third-party network hop, and no cross-border transfer. Access is authenticated against ASTRA's own cloud identity system, which means **BKS holds no key that reaches your documents**. Amazon does not keep what is sent to Bedrock and does not use it to train the models.

We suggest Model A for the proof of concept only because it can be stood up in days, where provisioning an account, network and access approvals inside ASTRA typically takes weeks. If ASTRA's security policy requires the proof of concept itself to run on ASTRA infrastructure, we will run it on Model B and adjust the schedule.

On Model C, honestly. The application itself runs on-premise without difficulty — it is a single self-contained package with file-based storage, no separate database server and no supporting infrastructure to install. What does not carry over is the AI. A genuinely disconnected deployment means running an open-source model on your own hardware, and **we have not measured extraction accuracy on one**. We are not willing to quote you an accuracy figure we have not measured. If Model C is a hard requirement, we should add an open-model benchmark to the proof of concept and price the outcome afterwards. Part Two, under "The self-hosted option", sets out what that choice buys and what it costs.

What we need from ASTRA to close this

1. Confirmation of the required model — A, B or C.
2. The approved region. We have assumed UAE unless told otherwise.
3. Whether ASTRA requires encryption keys held under ASTRA's own control.
4. Whether ASTRA IT provisions the cloud account and network, or BKS deploys into an account ASTRA provides.

3. The AI: how it works, what it costs, what it depends on, how it is secured

3.1 The design, in one page

Every piece of AI reading in the system — quotations, technical datasheets, requirement documents, deviation lists, meeting minutes, vendor suggestions — goes through a **single doorway with one instruction**. Behind that doorway sit five interchangeable connections:

Connection	How it authenticates	Where the data goes	Status
Amazon Bedrock	Cloud identity, no shared key	Stays inside the cloud region	Built; live testing is a proof-of-concept task
Anthropic	API key	Encrypted connection to Anthropic	Built and in production use
OpenAI	API key	Encrypted connection to OpenAI	Built and tested against a simulator, not yet against the live service
Google Gemini	API key	Encrypted connection to Google	Built and tested against a simulator, not yet against the live service
Simulator	none	No network connection at all	Used by the entire automated test suite

Two properties of this design speak directly to your query.

What we ask the AI is a document you can read. The instructions given to the model are versioned files kept alongside the source code, not text buried inside a program. Any change to them is a reviewable, dated change. ASTRA can be given read access to that directory as a condition of contract — see §7. A control you cannot read is not a control you can verify.

All the arithmetic stays in ordinary code. The AI's only job is to read a vendor's document and report the figures and units it finds, exactly as written. Every comparison, compliance judgement, currency conversion and ranking is then performed by conventional, testable, auditable software. **No model is ever asked whether a vendor complies.** This is the single most important control in the system: an award recommendation is produced by deterministic code working on figures traceable back to a page in a vendor's document — not by an AI's opinion.

3.2 What actually happens to a document

5. It is uploaded over an encrypted connection, and its contents are checked for tampering before anything is written to disk.
6. The **text is extracted on our own servers**. Images, drawings and binary content are not transmitted in the default configuration.
7. The text is split into manageable sections along line boundaries.
8. Each section is sent to the configured AI with the versioned instruction, and comes back as structured data — figures and units, never conclusions.
9. The results are merged all-or-nothing and stored against the source document, page and vendor.
10. Comparison, compliance checking, currency normalisation and ranking then run entirely in conventional code. **No AI is involved at this stage at all.**

To give a sense of scale: roughly **13 MB of plain text leaves the boundary for every 500 MB of source documents** — and under Model B, that "boundary" is ASTRA's own cloud region.

3.3 Where your data lives

Data	Where it lives under Model B	Does it cross a border?
Uploaded documents	ASTRA storage, ASTRA region	No
Extracted figures and comparison results	ASTRA storage, ASTRA region	No
User accounts, sessions, audit trail	ASTRA storage, ASTRA region	No
Vendor registry	ASTRA storage, ASTRA region	No
Text sent to the AI	Amazon Bedrock, same ASTRA region	No
What the AI returns	Back to the ASTRA region, stored there	No

On training. Under Amazon Bedrock's terms, what you send is not retained and is not used to train models. Under Anthropic's and OpenAI's commercial terms, business data is excluded from training by default. Part Two sets out the detail, including the important distinction between "not used for training" and "not stored at all". We will attach the providers' current published terms to the contract and re-confirm them at signature, rather than asking you to rely on this paragraph.

3.4 Running costs — measured, not estimated

These figures come from replaying a real multi-vendor tender through the production system, not from a spreadsheet model of what it might cost.

Measure	Value	Basis
AI calls per tender	about 102	measured — 37 documents, 4 vendors
Elapsed time per tender today	about 34 minutes	measured, processing one document at a time
Text yielded per megabyte of source	18,470 characters	measured on searchable PDFs
Overhead multiplier	×1.46	measured

The assumption most likely to be wrong for ASTRA is the third one. Searchable PDFs yield about 18,470 characters per megabyte. Scanned drawings yield almost nothing and therefore cost almost nothing; spreadsheets can yield several times more. **Measuring this against ASTRA's actual document mix is a primary objective of the proof of concept.** It is the number that drives your bill, and we will not contract a usage rate before we have measured yours.

One disclosure. Usage is **not currently metered inside the platform**. The figures above came from a separate measurement exercise. A built-in usage meter with a per-run cost record is a Phase 1 deliverable, and it must be in place before any usage-based billing begins. We are telling you this rather than letting you discover later that the meter behind the pricing model does not yet exist.

Two levers reduce this cost, both already in Phase 1 scope: submitting work in batches, which roughly halves the AI cost with no change to the output; and caching the fixed portion of each instruction, which removes repeated charges for text that never changes.

3.5 Dependency on any one AI provider

A fair concern, and the design already answers most of it.

- **Changing provider is a configuration change, not a development project** — a single setting, which can even be varied per run. The single-doorway design exists precisely so that no one provider becomes load-bearing.

- **Under Model B, your dependency is on Amazon, not on an AI vendor as a counterparty.** Bedrock offers several model families, so a model being retired becomes a setting change inside an existing contract.
- **Model versions are pinned.** The exact model is explicit configuration. ASTRA is never silently moved onto a new model. Any change is a controlled event, with the accuracy benchmark re-run against the proof-of-concept corpus.
- **Honest caveat.** The OpenAI and Gemini connections are built and unit-tested but have not been exercised against the live services. If ASTRA wants a contractually guaranteed second provider, testing that connection live is a named proof-of-concept deliverable — not something to assume.

3.6 Security controls in the platform itself

Built and testable today:

Control	How it works
Sign-in	Closed by default. Every service address requires a valid session except exactly three — health check, sign-in and sign-up — and that list is pinned by an automated test, so a new feature is protected the day it is written rather than the day someone remembers.
Passwords	Stored using a deliberately slow one-way algorithm with a unique salt per password. The stored value is structurally incapable of appearing in any response the system sends.
Sessions	Only a one-way fingerprint of the session token is stored, never the token. Sessions expire when the browser closes, and restarting the service signs everybody out.
Permissions	Two roles, administrator and reviewer, set once when the account is created; no feature can change a role afterwards. Access to each project is enforced on every request by the server — not by hiding menu items.
Upload safety	One strict check for the whole system, applied to every uploaded archive and folder. It refuses a suspicious path outright rather than testing where it would land, and normalises both Windows and Unix path styles first — so an attack that only works on Windows is still refused on Linux.
Data in transit	Encrypted, including every call to the AI.
Data at rest	Encrypted, with customer-controlled keys available under Model B.
Audit trail	Every classification, extraction, manual override, stage change and re-run is recorded with who did it and when. Enquiry history is add-only: going back a stage adds an entry, it never rewrites one.
Secrets	Never built into a deployable package unless explicitly requested; credential files are excluded from the build.
Concurrent edits	Every write, and every decision that permits a write , happens inside a single locked section — so two people acting at the same moment cannot both be told "yes" to something only one of them should get.

Two known exposures, disclosed rather than hidden. Both are development conveniences that must be closed before any ASTRA deployment, and both are named hardening items in Appendix C:

- 11.A development sign-in bypass exists — off by default — which serves an unauthenticated visitor as the first administrator. It must be verified off and removed from production builds.
- 12.The current sign-in screen carries a demonstration-account shortcut that embeds a demo password in the page. It is removed for ASTRA.

Not yet in place, and we would rather say so: single sign-on with your corporate identity provider (a named customisation item), multi-factor authentication, IP allow-listing, a penetration-test report, and a SOC 2 attestation for BKS as an organisation. The certifications of the infrastructure underneath us — Amazon's SOC reports, ISO certifications and so on — are **Amazon's, not ours**, and we will not present them as ours. Part Two explains exactly where that line falls.

4. Customisation cost — what exactly do we get?

Accepted

A customisation figure with no schedule of deliverables behind it is an invitation to a change-order dispute, and you are right to refuse it. **Appendix C is a fixed-scope matrix:** every deliverable named, quantified with a countable unit, and either inside the fixed price or explicitly outside it.

The four principles we propose contracting on

13. **Every deliverable carries a countable unit** — "3 enquiry templates", "2 approval workflows", "1 ERP integration, 4 connection points" — never "workflow configuration".
14. **Anything not named in Appendix C is outside the fixed price**, and both parties can see that at signature rather than at month four.
15. **A change request is priced against a published day rate before work begins**, never invoiced afterwards.
16. **A configuration change is not a change request.** Adding a discipline, a vendor, a template, a user or a report filter is self-service and free, permanently. Appendix C draws the line between configuration and development explicitly, because that line is where change-order disputes actually begin.

Appendix C covers **six procurement use cases end to end**. We propose that the proof of concept confirms that list against ASTRA's real process before the customisation price is fixed — pricing a workflow build before seeing your actual material requisition and enquiry flow is exactly how an estimate goes wrong.

5. The ten-user limit

Accepted

Ten seats was sized for a pilot — one procurement team proving the tool on real tenders. It is the wrong shape for a platform used across Procurement, Engineering, Estimation and Projects, and holding you to it would produce the outcome neither of us wants: people sharing logins, which destroys the attributed audit trail that is one of the platform's main arguments.

Three structures, for ASTRA to choose

	Option 1 — Named seats	Option 2 — Departmental bands	Option 3 — Enterprise
Shape	Per named user	Per department band	Unlimited named users
Best when	Under about 30 users	30–100 users across four functions	An organisation-wide standard
Included	10 seats, then \$75 per user per month (<i>indicative</i>)	Banded at 25 / 50 / 100 seats	All ASTRA staff
Usage allowance	Shared pool — extra seats draw on the same allowance and are never rationed	Shared pool	Shared pool
Our view	Fine for the proof of concept	Recommended for a rollout across four functions	If ASTRA standardises platform-wide

Two commitments regardless of which is chosen:

- **An additional seat is never charged twice.** It carries no separate usage allowance of its own; it draws on the account's shared pool, so a user's work is billed once or not at all.

- **Read-only and occasional users cost nothing.** Approvers, engineering reviewers and managers who read a comparison but never run one should not consume a paid seat. We propose a free read-only role, capped at a multiple of paid seats, written into the commercial schedule.

Final seat counts should be set from what the proof of concept measures, not guessed now. We would rather size this from your real usage than sell you fifty seats and watch thirty-one of them sit idle.

6. Engineering AI scope

Accepted without reservation

The engineering AI scope in the proposal is broad, unmeasured and not costed against deliverables. We are **withdrawing it from Phase 1** rather than defending it.

Why

Everything we have quoted an accuracy or cost figure for in this document was measured against a real tender corpus. We have no equivalent measurement for the engineering scope. A scope with no measurable acceptance criterion cannot be accepted, cannot be tested and cannot be signed off — and including it would place a large unmeasured item beside a set of carefully measured ones, lending it credibility it has not earned.

Proposed re-scoping

Phase 1, contracted now: enquiry management and bid evaluation. No engineering AI.

Phase 3, optional and priced separately once Phase 1 is live: two or three named engineering use cases, each with a written acceptance criterion, each independently cancellable.

Ref	Deliverable	How success would be measured
E-1	Technical deviation extraction — a structured deviation register built from vendor technical submissions	Agreed recall percentage against a register built by hand, on an agreed number of real submissions
E-2	Datasheet parameter extraction — named parameters per equipment class	Agreed field accuracy per class, on an agreed number of datasheets
E-3	Specification compliance check — a requirement-by-requirement compliance matrix	Agreed level of agreement with an engineer's manual matrix
E-4	Drawing and bill-of-materials extraction	Not proposed. It requires reading images, which we have not measured.

The thresholds and sample sizes would be set jointly from the proof-of-concept baseline. **We will not propose E-4 until we have measured it** — the same discipline that led us to withdraw the broad scope in the first place.

7. Ownership, source code, data, AI instructions — and continuity if BKS stops

Answerable in full, and we regard the answers below as contractual.

7.1 Who owns what

Asset	Owner	Notes
All ASTRA data — documents, extracted figures, comparisons, vendor registry, audit trail, user accounts	ASTRA, unconditionally	Yours during the term and after it. Not conditional on payment status, notice period or renewal.
ASTRA-specific configuration — templates, disciplines, approval workflows, report layouts, integration mappings	ASTRA	Delivered as readable files, not as opaque rows inside a database.
ASTRA-specific AI instructions — anything tuned to ASTRA's document formats	ASTRA	Versioned files, delivered with the configuration.
Base platform source code	BKS , licensed to ASTRA perpetually for internal use	See 7.3 for the continuity mechanism.
Base platform AI instructions	BKS, provided to ASTRA under the licence	ASTRA gets read access for audit — a control you cannot read is not a control you can verify.
The underlying AI models	Anthropic, OpenAI or Amazon	Neither party owns these; they are third-party services.

ASTRA's data is never used to improve a product sold to anyone else. No ASTRA document, extraction or comparison is used to tune instructions, build benchmarks or train anything used outside ASTRA's own deployment. We will contract on this.

7.2 Getting your data out

This is the strongest answer we can give you, because there is no proprietary database and no proprietary file format anywhere in the system.

What you take out	Format	Readable without BKS software?
Every uploaded document	The original files, unmodified, in ordinary folders	Yes — they are your files
Extracted figures and comparison results	Plain structured text files	Yes — any text editor
Audit and event log	Plain text, one entry per line, add-only	Yes
Vendor registry	An open database format, plus Excel and CSV export	Yes
Enquiry workflow — projects, items, RFQs, shortlists, clarifications	A single structured text document	Yes
Accounts and access grants	Plain structured text	Yes
Comparisons and compliance matrices	Excel and CSV export	Yes — Excel
Configuration and AI instructions	Plain text files	Yes

There is **no proprietary binary format, no encrypted vendor-locked store, and nothing that requires BKS software to interpret**. A full export is a copy of a folder. We propose contracting a **quarterly automatic export into a storage location ASTRA owns**, so a current copy is continuously in your hands rather than requested at the point of a dispute.

7.3 If BKS support ends

Four mechanisms, in ascending order of protection. ASTRA should choose the level appropriate to how critical the platform becomes.

17. **Source code escrow** with a recognised agent, released on defined triggers: insolvency, acquisition without the contract transferring, or failure to meet the support commitment for a defined period.
18. **Perpetual internal-use licence**, so on termination ASTRA may keep running the version in place indefinitely. Under Model B this is meaningful rather than theoretical — the software already runs in your own account.
19. **Documented handover** — deployment runbook, architecture documentation and configuration inventory maintained as a contractual deliverable, rather than produced under exit pressure.
20. **Transition assistance** — a defined number of support days at a pre-agreed rate during a 90-day transition, whichever party terminates.

One thing worth stating plainly. Under Model B, if BKS disappeared tomorrow, the platform keeps running. It is a self-contained application in ASTRA's account, calling Amazon's AI service in ASTRA's account, reading and writing files ASTRA owns. Nothing calls home to BKS and no licence check phones out. What ASTRA loses is future development and support — not access to the system or to the data.

8. The proposed proof of concept — agreed

We agree, and we would have proposed it had you not. Your framing is better than ours, because it names the acceptance criteria up front.

Design

Duration	6 weeks — 4 weeks running, 2 weeks measurement and reporting
Input	ASTRA's real enquiry packages and vendor quotations — not a demonstration set
Volume	3–5 completed tenders ASTRA has <i>already evaluated manually</i> , so there is a known-correct answer to measure against
Deployment	Model A unless ASTRA policy requires Model B
Users	5–8 ASTRA users across Procurement and Engineering
Fee	\$7,500, credited in full against a first-year agreement signed within 60 days of completion
If ASTRA stops at week 6	ASTRA keeps every comparison, every export and the full measurement report. Nothing to unpick.

The seven things you asked us to measure

#	Measure	Method	Proposed pass mark
1	Extraction accuracy	Field by field against ASTRA's own manually built comparative statement	95% of commercial fields; 90% of technical parameters (<i>to confirm</i>)
2	Comparison accuracy	Does the ranked outcome match what your team reached by hand — and where it differs, which one is right?	Full agreement on the compliant / non-compliant call, or a documented reason for every difference
3	Time saving	ASTRA records the hours spent manually; we record the hours through the platform on the same tenders	60% reduction (<i>to confirm</i>)
4	Security	ASTRA IT review against §3.6 and Part Two, plus a walkthrough of exactly where data goes	ASTRA sign-off, no unresolved high findings
5	Integration effort	A workshop with ASTRA IT covering ERP, single sign-on and mail	A costed integration plan, not an estimate
6	Total cost of ownership	Measured usage on ASTRA's own document mix, plus infrastructure, plus support	A three-year cost model built from measured figures, not planning rates

#	Measure	Method	Proposed pass mark
7	Document-mix calibration	Measured text yield across ASTRA's actual mix of scanned, searchable and spreadsheet documents	A baseline established — and it becomes the contractual basis for any usage pricing

Measure 7 is the one we most want from this exercise, because it is the number our entire cost model rests on, and we currently hold ASTRA's value at zero. Our planning figure is 18,470 characters per megabyte, measured on searchable PDFs. If your packages are heavily scanned, that figure collapses and so does the cost; if they are spreadsheet-heavy, it rises. **We are not willing to contract a usage rate against ASTRA's documents before we have measured ASTRA's documents.**

Full criteria at Appendix D.

What we need from ASTRA to start

21. Three to five completed, manually evaluated tender packages, with the comparative statement your team produced.
 22. The hours those tenders actually took, if recorded — otherwise a considered estimate from the people who did the work.
 23. A named ASTRA owner for the exercise, and 5–8 users.
 24. A security review slot with ASTRA IT in week 1, not week 6.
 25. Agreement on the pass marks **before** we start, so the result is a fact rather than an argument.
-

Part Two — Security and compliance of the technology underneath

This part answers the compliance question directly: *what protects ASTRA's data once it is inside this system, and whose word does each protection rest on?*

The one idea to take from this section

There are **three separate layers**, each with its own certifications, and **no layer's certificate covers the layer above it**.

Layer	Who is responsible	What their certifications prove
1 — The cloud infrastructure (Amazon)	Amazon	The data centres, hardware, network and encryption machinery are audited and certified to international standards.
2 — The AI service (Amazon Bedrock, or Anthropic / OpenAI directly)	The AI provider	How your text is handled during processing: whether it is stored, for how long, who can see it, and whether it trains anything.
3 — The application (this platform)	BKS, and then ASTRA	How users sign in, who can see which project, what is recorded in the audit trail, and how documents are handled.

Buying certified infrastructure does not make an application compliant. It provides certified building blocks from which a compliant system can be built. That distinction is the whole of the shared-responsibility model, and it is why §3.6 exists as a separate list from everything below.

Layer 1 — The cloud infrastructure (Amazon Web Services)

Amazon's infrastructure carries the broadest compliance portfolio in the industry, and it is the foundation everything else in this proposal sits on.

Independent audit reports. Amazon's infrastructure is audited for SOC 1, SOC 2 and SOC 3 — reports produced by independent auditors confirming that Amazon's security controls are both properly designed and actually working. The SOC 2 Type 2 report matters most for a vendor risk assessment, because it provides evidence that the controls operated effectively *over a period of time*, rather than a snapshot on one day.

International standards. Amazon maintains a suite of ISO certifications, verified by an accredited certification body:

Standard	What it covers, in plain terms
ISO/IEC 27001:2022	The foundation: how information security risks are identified, assessed and treated across the organisation.
ISO/IEC 27017:2015	The cloud-specific extension — clarifies who is responsible for what between provider and customer.
ISO/IEC 27018:2019	Protection of personal data in public cloud environments.
ISO/IEC 27701:2019	Privacy management, and the standard normally used to demonstrate alignment with GDPR.
ISO/IEC 42001	A newer standard specifically for the management of artificial intelligence — directly relevant to Amazon Bedrock.
CSA STAR Level 2	An independent third-party audit against the Cloud Security Alliance's cloud controls framework.

These cover services from core computing and storage through to Amazon Bedrock, the AI service we propose using.

Encryption keys. Amazon's Key Management Service — the machinery that holds encryption keys — has been certified to **FIPS 140-3 Security Level 3**, the US federal standard for cryptographic hardware. Level 3 requires physical tamper-resistance and identity-based authentication. In practical terms: your encryption keys exist only inside tamper-resistant hardware, only in memory, and only for the instant needed to perform an operation. They are never written to disk. Even Amazon's own data-centre staff physically cannot extract them.

Government and healthcare. Amazon holds FedRAMP High and Moderate authorisations for US government workloads, and offers over 166 services eligible for use with protected health information under HIPAA, subject to the appropriate agreement.

Staying compliant over time. Compliance drifts as engineers create new resources. Amazon provides continuous automated checking against recognised security benchmarks, so a misconfigured storage bucket or an unencrypted database is flagged immediately rather than discovered at the next audit.

Layer 2 — The AI service

This is where the "does our data train their model?" question lives, and it deserves a precise answer, because two different things are often confused.

The two questions that are not the same question

"Is our data used to train the model?" and "Is our data stored at all?" are separate questions with separate answers. A provider can honestly say your data never trains anything while still keeping a copy for a period, for the purpose of detecting abuse of the service. Both matter; they are managed by different mechanisms.

Anthropic (the provider currently in production use)

- **Independently audited:** SOC 2 Type 2 and SOC 3. The SOC 3 report is public, which makes it useful for a quick vendor assessment.
- **Certified:** ISO/IEC 27001:2022 for information security management, and ISO/IEC 42001:2023 for AI management specifically. Also CSA STAR Level 2, UK Cyber Essentials, and alignment with the US NIST 800-171 framework for controlled unclassified information.
- **Training:** business data submitted through the commercial API is **not** used to train foundation models, by default and by contract.
- **Retention:** historically a 30-day window for abuse monitoring. A **zero-retention mode** is available for enterprise customers, which deletes the record as soon as the response has been produced.
- **Healthcare and Europe:** a HIPAA report and business associate agreements are available; GDPR is supported through a data processing addendum incorporating standard contractual clauses.
- **Customer-managed encryption keys** are available, meaning ASTRA could hold the keys to its own data inside the provider's systems — and withdrawing those keys renders the data permanently unreadable.
- **Government:** FedRAMP High authorisation is available through specific government offerings and through Amazon's government cloud.

OpenAI

- **Independently audited:** SOC 2 Type 2, covering security, availability, confidentiality and privacy.
- **Certified:** ISO/IEC 27001:2022, 27701:2019, 27017 and 27018, plus ISO/IEC 42001:2023 for AI management. CSA STAR Level 1 for the API platform.
- **Training:** data submitted through the API and the enterprise products is **not** used to train or improve models, by default. The customer retains ownership of both inputs and outputs.

- **Retention:** by default, inputs and outputs are kept for **up to 30 days** purely to detect misuse. Access during that window is restricted to a small number of authorised staff responding to incidents or legal obligations.
- **Zero data retention:** available to eligible enterprise customers. When enabled, requests are processed entirely in memory and discarded immediately, and the content is excluded from abuse-monitoring logs and never seen by a human. Two limits are worth knowing: it cannot apply to features that are *designed* to store things — stored conversations, assistant threads, or document search indexes — and a small encrypted performance cache may persist briefly, inaccessible for review.
- **Healthcare and Europe:** business associate agreements for HIPAA; a data processing addendum with standard contractual clauses for GDPR.

Amazon Bedrock — the option we recommend

Bedrock is Amazon's managed service for running these same models **inside your own cloud account and region**. It is the reason we recommend Model B, and it changes the compliance conversation in three ways:

26. **There is no third-party AI vendor in the data path at all.** Your text goes to a service running inside your own account. Nothing crosses a border and no external provider receives your documents.

27. **Amazon does not retain what is sent to Bedrock and does not use it to train models.**

28. **Access is authenticated by your own cloud identity system**, so BKS holds no credential that can reach your data.

In effect, Model B lets ASTRA inherit Layer 1's certifications for Layer 2 as well, rather than having to assess an additional vendor.

The self-hosted option (open models on your own hardware)

For organisations requiring absolute data sovereignty or genuinely disconnected networks, the alternative is to run an open-source model on your own machines using a local inference engine such as Ollama. This is the technical basis of Model C in §2, and it is worth being precise about what it does and does not give you.

What it gives you. The model runs entirely on your own hardware, with no internet connection required and no telemetry back to anyone. Third-party subprocessor risk disappears entirely. Data cannot cross a border because it never leaves the machine. Genuinely air-gapped operation is possible: model files are downloaded on a connected machine, transferred by secure media, and then run indefinitely with no network connection at all.

What it does not give you, and this is the part usually missed. A local inference engine is *software*, not a service — so it holds no SOC 2 report, no ISO certification and no HIPAA agreement of its own, and there is nobody to obtain one from. Compliance is not inherited; it is **assumed by you**. Your own team must implement role-based access control, patch the host operating systems, encrypt the stored model files and conversation histories, enforce encrypted internal traffic, and maintain audit logs tying every request back to a named user — and then present all of that to your own auditor. The audit boundary shrinks to your own perimeter, which is exactly the appeal, but everything inside it becomes your responsibility.

There is also no such thing as an officially certified hosted version of this software. Where such a service is offered, the compliance being relied on belongs to whoever is hosting the machines, not to the inference software.

And the practical caveat we repeat from §2: we have not measured extraction accuracy on an open model against tender documents, and we will not quote a figure we have not measured. If Model C is a hard requirement, an open-model benchmark should be added to the proof of concept.

Layer 3 — This platform, and where BKS's responsibility begins

Everything in §3.6 belongs to this layer, and it is the layer Amazon's and Anthropic's certificates say nothing about. To restate the boundary in one paragraph:

Amazon certifies the infrastructure. The AI provider certifies how your text is handled during processing. Neither of them certifies who in ASTRA can see which tender, whether the audit trail is complete, or whether an uploaded file is checked before it is written to disk. That is our layer, and it is assessed by ASTRA's own security review during the proof of concept — which is why we have asked for that review in week 1 rather than week 6.

Two statements of fact about that layer, restated here because they are the ones most often assumed:

- **BKS does not hold a SOC 2 attestation as an organisation.** We have not commissioned one. The certifications listed above belong to Amazon, Anthropic and OpenAI. We will not present them as ours.
- **BKS has not commissioned a penetration test.** If ASTRA requires one before production go-live, it can be commissioned; it is not something we can produce today.

The consolidated verification matrix at Appendix A lists every certification named in this document, what it means, and where ASTRA can verify it independently. It is laid out so it can be lifted directly into a vendor risk assessment.

Which combination we recommend for ASTRA

	Recommended	Why
Infrastructure	Amazon, in a region ASTRA approves	The broadest certification portfolio available, and it is the layer everything else rests on
AI service	Amazon Bedrock in ASTRA's own account	No third-party AI vendor in the data path; no border crossing; no BKS-held credential that reaches your data
Encryption keys	Customer-managed, held by ASTRA	ASTRA retains the ability to render its own data unreadable, independently of BKS
Retention	Nothing retained by the AI service	A property of Bedrock, not something we have to negotiate
Application layer	This platform, hardened per Appendix C, reviewed by ASTRA IT in week 1	The one layer no external certificate covers

If ASTRA's policy instead requires a direct provider relationship, the equivalent posture is Anthropic or OpenAI with **zero data retention** formally enabled at organisation level, plus the appropriate data processing addendum. That is a good position; Model B is a stronger one, because it removes the question rather than answering it.

Part Three — What is not built

Every limitation named anywhere in this document, in one place, so ASTRA can plan against it. This section exists because we would rather lose on an honest scope than win on an implied one.

#	Gap	What it means for ASTRA	Plan
G-1	Now closed. Our 18 August response listed "no mail transport" as a gap. Outbound enquiry mail is built, tested and has issued real enquiries.	Nothing — but pointing it at ASTRA's own mail infrastructure remains a configuration task	Configuration item in Appendix C
G-2	No ERP or SAP integration built	Purchase orders are handed over manually	Customisation item, scoped during the proof of concept
G-3	No single sign-on with your corporate identity	Separate credentials for this platform	Customisation item
G-4	Usage is not metered inside the platform	Usage-based billing cannot begin	Phase 1 deliverable, before any usage billing
G-5	Documents are processed one at a time — about 34 minutes per tender	A throughput ceiling under heavy load	Phase 1: parallel processing, targeting 4–8 minutes per tender
G-6	The OpenAI and Gemini connections have not been tested against the live services	A guaranteed second provider is unproven	Live testing as a proof-of-concept deliverable if ASTRA wants a contracted alternative
G-7	The Amazon Bedrock connection is built but not yet wired into a deployed configuration	Model B depends on this	Proof-of-concept deliverable — the first thing we do
G-8	Cloud object storage is not yet implemented; storage is local today	Affects how storage scales, not whether it works	Phase 1. The storage interface already exists, so this is an addition rather than a rebuild
G-9	A development sign-in bypass and a demo-credential shortcut exist in the codebase	Must not reach an ASTRA deployment	Phase 1 hardening, verified in ASTRA's own security review
G-10	Reading scanned drawings as images is not enabled	Image-only drawings yield no text today	Deliberate — it is off by default and costs nothing. Enabling it changes the cost model materially and is a priced decision after we measure how much of your corpus is scanned
G-11	The cost-estimation module is command-line only	Not usable by ASTRA today	Outside Phase 1; a Phase 3 candidate
G-12	No SOC 2 attestation for BKS as an organisation	ASTRA relies on Amazon's certifications plus contractual terms with us	Disclosed; on our roadmap, not claimed today
G-13	No penetration test report	ASTRA may require one	Can be commissioned before production go-live if required
G-14	On-premise (Model C) extraction accuracy is unmeasured	Model C cannot be quoted with an accuracy figure	Add an open-model benchmark to the proof of concept only if Model C is a hard requirement
G-15	No multi-factor authentication or IP allow-listing	Sign-in is single-factor today	Deliverable alongside single sign-on, which supersedes both when your identity provider enforces them

Part Four — What we propose happens next

#	Action	Owner	By
1	Confirm deployment model (A / B / C) and approved region	ASTRA	Week 1
2	Confirm whether purchase-to-payment scope is required, or whether enquiry management and evaluation is the target	ASTRA	Week 1
3	Security review slot booked with ASTRA IT	Both	Week 1
4	Select seat structure (Option 1 / 2 / 3) for pricing	ASTRA	Week 2
5	Rank the Phase 3 engineering candidates E-1 to E-3, or defer them	ASTRA	Week 2
6	Select continuity level — escrow, perpetual licence, or both	ASTRA	Week 2
7	Joint workshop: agree the proof-of-concept pass marks and finalise Appendix C	Both	Week 2
8	Re-issued proposal — corrected scope, one deployment model, fixed deliverables matrix	BKS	Week 3
9	Proof of concept starts	Both	Week 4

Appendix A — Compliance verification matrix

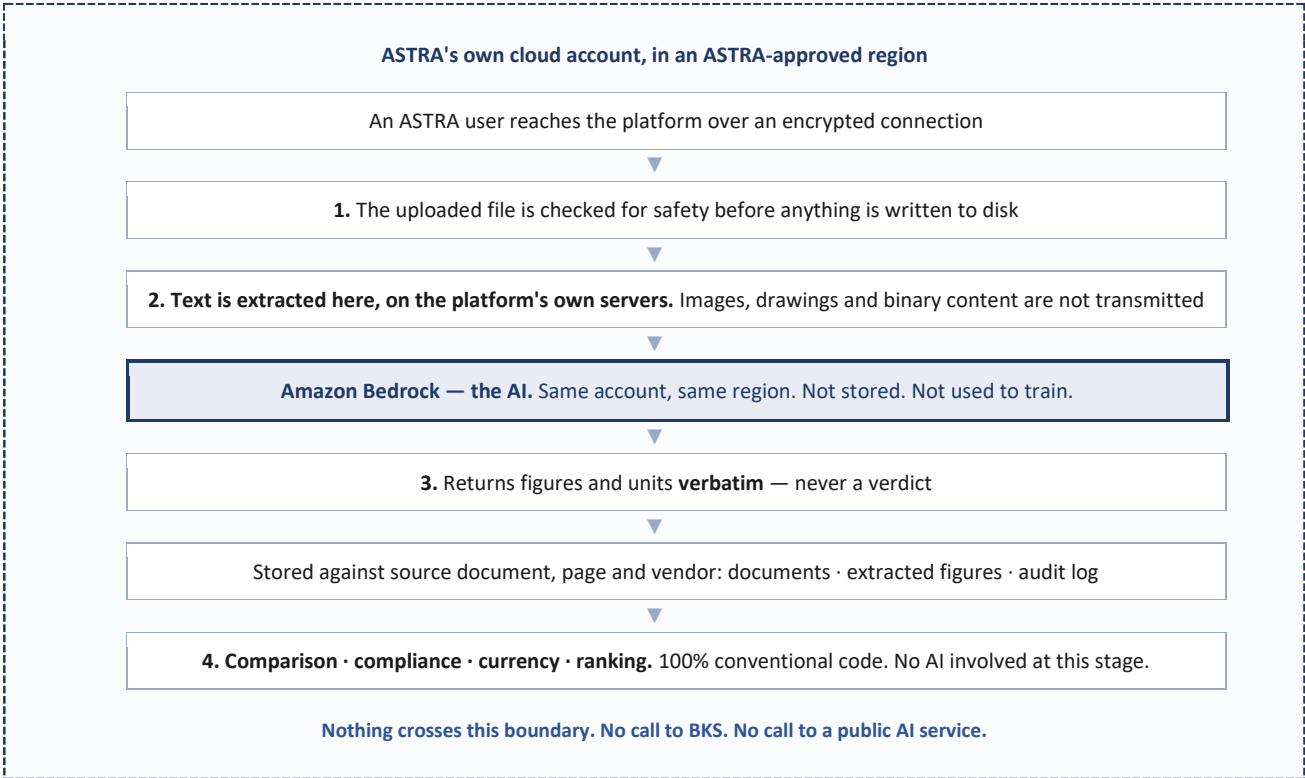
Every certification referenced in this document, what it means, and where ASTRA can verify it independently. Laid out for direct transfer into a vendor risk assessment.

Provider	Compliance code	What it means	Where to verify
AWS	SOC 1, SOC 2, SOC 3	Independent audit reports verifying the design and operating effectiveness of security, availability and confidentiality controls	AWS Compliance Programs
AWS	ISO/IEC 27001:2022	The foundational international standard for an information security management system	AWS ISO certification page
AWS	ISO/IEC 27017:2015	Cloud-specific security controls, defining the split of responsibility between provider and customer	AWS ISO certification page
AWS	ISO/IEC 27018:2019	Protection of personal data in public cloud environments	AWS ISO certification page
AWS	ISO/IEC 27701:2019	Privacy information management; the usual basis for demonstrating GDPR alignment	AWS ISO certification page
AWS	ISO/IEC 42001	Management system standard for artificial intelligence — responsible and secure AI governance	AWS Compliance Programs
AWS	FIPS 140-3 Level 3	US federal standard for cryptographic hardware. Level 3 requires physical tamper-resistance and multi-party authentication. Applies to AWS Key Management Service	AWS KMS announcement; NIST CMVP certificate #4884
AWS	FedRAMP High / Moderate	US federal authorisation permitting highly sensitive unclassified government data	AWS Compliance Programs
AWS	HIPAA BAA	Business associate agreement permitting protected health information in the cloud environment	AWS HIPAA compliance documentation
AWS	CSA STAR Level 2	Independent third-party audit against the Cloud Security Alliance's cloud controls matrix	AWS ISO certification page
Anthropic (API)	SOC 2 Type 2 and SOC 3	Independent audits of security, availability and confidentiality for the API and enterprise platforms. The SOC 3 report is public	Anthropic Trust Center
Anthropic (API)	ISO/IEC 27001:2022	Certified information security management system covering the API and enterprise environments	Anthropic Trust Center
Anthropic (API)	ISO/IEC 42001:2023	Certified AI management system — AI risk assessment and lifecycle governance	Anthropic Trust Center
Anthropic (API)	HIPAA Type 1 report and BAA	Permits healthcare entities to process protected health information	Anthropic Trust Center
Anthropic (API)	FedRAMP High	Authorisation to process highly sensitive US government data, via specific government offerings or Amazon's government cloud	Anthropic Trust Center
Anthropic (API)	CSA STAR Level 2	Independent third-party cloud security audit	Anthropic Trust Center
Anthropic (API)	Zero data retention	Inference records deleted immediately after the response is produced, bypassing the standard abuse-monitoring window	Anthropic commercial terms
Anthropic (API)	Customer-managed encryption keys	ASTRA holds the keys to its own data; withdrawing them renders it permanently unreadable	Anthropic Trust Center
OpenAI (API / Enterprise)	SOC 2 Type 2	Independent audit of security, privacy and confidentiality controls over a reporting period	OpenAI security and privacy page

Provider	Compliance code	What it means	Where to verify
OpenAI (API / Enterprise)	ISO/IEC 27001:2022	Certified information security management system	OpenAI security and privacy page
OpenAI (API / Enterprise)	ISO/IEC 27017 and 27018	Cloud security controls and protection of personal data in public cloud	OpenAI security and privacy page
OpenAI (API / Enterprise)	ISO/IEC 27701:2019	Privacy information management, extending the 27001 system	OpenAI security and privacy page
OpenAI (API / Enterprise)	ISO/IEC 42001:2023	Certified AI management system covering business AI products	OpenAI security and privacy page
OpenAI (API / Enterprise)	CSA STAR Level 1	Cloud Security Alliance registry entry for the API platform	OpenAI security and privacy page
OpenAI (API / Enterprise)	HIPAA BAA	Business associate agreement for eligible healthcare customers	OpenAI enterprise privacy page
OpenAI (API / Enterprise)	GDPR DPA with SCCs	Data processing addendum with standard contractual clauses governing EU data transfers	OpenAI enterprise privacy page
OpenAI (API / Enterprise)	Zero data retention	Inputs and outputs fully ephemeral, bypassing the 30-day abuse-monitoring window on eligible endpoints	OpenAI API data controls guide
Self-hosted (e.g. Ollama)	Local / air-gapped execution	An architectural property, not a certification. Processing happens entirely on your own hardware with no external transmission	Provider privacy documentation
Self-hosted (e.g. Ollama)	Inherited compliance	Because data never leaves your boundary, compliance rests entirely on your own infrastructure controls. There is no certificate to obtain for the software itself	Your own security controls and audit evidence
BKS Solutions	None held	Stated for completeness. BKS holds no SOC 2, ISO or equivalent attestation as an organisation, and no penetration test report. The controls in §3.6 are demonstrable but not externally attested.	ASTRA's own security review, week 1 of the proof of concept

Appendix B — Where your data sits, at a glance

Under **Model B**, the recommended production arrangement:



Under **Model A**, the boundary is a BKS-controlled account in a region ASTRA approves, and the AI step may run either on Amazon Bedrock in-region or against a provider API — ASTRA's choice, recorded in the contract.

Under **Model C**, the boundary is your own data centre, and the AI step runs on your own hardware — with the accuracy caveat in §2 and the responsibility transfer described in Part Two.

Appendix C — Customisation deliverables matrix

To be finalised jointly in the week 2 workshop. Quantities are indicative pending the proof of concept. Once signed, this matrix is the definition of the fixed price.

C.1 Inside the fixed price

Ref	Deliverable	Unit	Qty	How it is accepted
Workflows				
W-1	ASTRA approval workflow configured to your delegation-of-authority matrix	approval workflows	2	A test transaction through each, signed off by the ASTRA process owner
W-2	ASTRA stage-gate criteria mapped onto the eight built-in stages	stage-gate rules	up to 8	Each gate correctly permits and refuses on a test enquiry
W-3	Technical bid evaluation workflow using ASTRA's scoring model	evaluation workflows	1	Produces ASTRA's own evaluation output on a proof-of-concept tender
Templates				
T-1	Enquiry document templates in ASTRA format	templates	3	Comparable to an ASTRA-issued enquiry
T-2	Comparative statement matching ASTRA's exact Excel layout	templates	1	Opens in your own workbook without rework
T-3	Clarification and query register template	templates	1	ASTRA sign-off
T-4	Technical bid evaluation report template	templates	1	ASTRA sign-off
Integrations				
I-1	ERP integration — vendor master plus requisition and purchase order	connection points	4	Round-trip test against your non-production ERP
I-2	Mail configuration against ASTRA's own mail infrastructure	integrations	1	An enquiry issued to a test mailbox with a delivery record
I-3	Single sign-on with ASTRA's corporate identity provider	integrations	1	An ASTRA credential signs in; local passwords disabled
I-4	Vendor master import from ASTRA's approved vendor list	importers	1	Full list loaded, row count reconciled
Reports				
R-1	Standard reports — spend by discipline, cycle time by stage, vendor participation, clarification ageing	reports	4	Each renders on real data and exports to Excel
R-2	Management dashboard	dashboards	1	ASTRA sign-off
Platform				
P-1	Usage metering with per-run cost record and threshold alerts	1	1	The meter reconciles to the provider's invoice within 5%
P-2	Security hardening — development bypass removed, demo control removed, production build verified	1	1	Verified in the ASTRA security review
P-3	Parallel processing for throughput	1	1	A tender completes in 8 minutes or less at eight-way concurrency
Enablement				
E-1	Administrator training	sessions	2	Attendance, plus an administrative task completed unaided
E-2	End-user training	sessions	4	Attendance, plus a tender run unaided

Ref	Deliverable	Unit	Qty	How it is accepted
E-3	Documentation — administrator guide, user guide, operations runbook	documents	3	ASTRA sign-off

Use cases covered end to end by the above: six — (1) raise an enquiry from a material requisition; (2) shortlist from the approved vendor list with client approval; (3) issue the enquiry package to bidders; (4) run a clarification round; (5) receive and compare bids; (6) produce the technical evaluation and comparative statement for award.

C.2 Free configuration — never a change request

Adding or editing any of the following is self-service and free, permanently: disciplines and product groups · vendors and vendor contacts · users, roles and project access · enquiry metadata fields · report filters and saved views · approval thresholds within an existing workflow · currencies and exchange rates · document classes and file-naming rules · email recipient lists.

C.3 Explicitly outside the fixed price

Additional ERP connection points beyond the four in I-1 · additional integrations beyond I-2 to I-4 · a second ERP · custom mobile applications · contract lifecycle management · invoice matching or payment · reverse auctions · supplier performance scorecarding · catalogue purchasing · engineering AI use cases (\$6, Phase 3) · migration of historical tenders predating go-live · custom reports beyond the four in R-1.

Each is priced against a published day rate, quoted and approved **before** work begins.

Appendix D — Proof-of-concept acceptance criteria

Pass marks are proposals. They should be agreed in the week 2 workshop before the exercise starts, so that the result is a measurement rather than a negotiation.

#	Criterion	Method	Proposed pass	Evidence you receive
1a	Commercial field extraction accuracy	Field by field against your manual comparative statement, all tenders	95%	A per-field difference report, every divergence listed
1b	Technical parameter extraction accuracy	Against your manual technical comparison	90%	A per-parameter difference report
1c	Document classification accuracy	Against manual classification of every file in the corpus	95%	A classification accuracy matrix
1d	Revision handling	Every superseded document correctly retired	100%	A revision lineage report
2a	Ranked outcome agreement	Platform ranking against your manual award recommendation	Match, or a documented reason for each difference	Side-by-side ranking
2b	Compliance determination	The compliant / non-compliant call, per vendor per requirement	Full agreement, or a documented reason	Compliance matrix against yours
2c	Traceability	Every figure traceable to its source document and page	100%	Spot check of 50 randomly chosen figures
3	Time saving	Your recorded manual hours against platform hours, same tenders	60% reduction	Time log, both methods
4a	Security review	ASTRA IT review against §3.6 and Part Two, plus a data-flow walkthrough	Sign-off, no unresolved high findings	Review record
4b	Data residency verification	ASTRA verifies independently that nothing leaves the approved region	Verified by ASTRA	Network and flow evidence
5	Integration effort	Workshop with ASTRA IT on ERP, single sign-on and mail	A costed plan, not an estimate	Integration plan with day counts
6	Total cost of ownership	Measured usage on your document mix, plus infrastructure, plus support	A three-year model from measured figures	Cost model, every assumption sourced
7	Document-mix calibration	Measured text yield across your actual scanned / searchable / spreadsheet mix	Baseline established	Calibration report — the contractual basis for usage pricing
8	Throughput	Elapsed time per tender under production configuration	8 minutes or less at eight-way concurrency	Timing log

If criteria 1, 2 and 3 are not met, ASTRA does not proceed and owes nothing further. The fee covers the work either way, and ASTRA keeps every output and the full measurement report. We would rather find that out in six weeks on five tenders than in year one on five hundred.

Appendix E — Glossary

Term	Plain meaning
API	A connection point that lets two pieces of software talk to each other directly, without a person in between.
Air-gapped	A system with no network connection to the outside world at all.
BAA (Business Associate Agreement)	A contract required under US healthcare law before a supplier may handle patient data.
Bedrock	Amazon's managed service for running AI models inside your own cloud account.
CMEK / customer-managed keys	Encryption keys held by you rather than the supplier, so you can render your own data unreadable at will.
CSA STAR	A cloud security assurance programme. Level 1 is a self-assessment; Level 2 is an independent audit.
DPA (Data Processing Addendum)	The contract governing how a supplier processes personal data on your behalf under GDPR.
FedRAMP	The US government's cloud security authorisation programme. "High" is the most sensitive unclassified tier.
FIPS 140-3 Level 3	A US federal standard for encryption hardware; Level 3 requires physical tamper-resistance.
GDPR	The European data protection regulation.
HIPAA	US healthcare privacy law.
Inference	The act of an AI model producing an answer from an input. What you pay for, per use.
ISO/IEC 27001	The main international standard for managing information security.
ISO/IEC 42001	A newer international standard specifically for managing artificial intelligence responsibly.
KMS (Key Management Service)	The system that stores and protects encryption keys.
LLM (Large Language Model)	The kind of AI that reads and writes text. What this platform uses to read vendor documents.
Ollama	Open-source software for running AI models on your own hardware, with no internet connection.
On-premise	Running on your own servers, in your own building.
SCC (Standard Contractual Clauses)	Pre-approved contract wording that makes international personal-data transfers lawful under GDPR.
SOC 2 Type 2	An independent audit report showing a supplier's security controls worked correctly over a period of time, not just on one day.
Shared responsibility model	The principle that a cloud provider secures the infrastructure and the customer secures what they build on it. Neither covers the other.
ZDR (Zero Data Retention)	A mode in which an AI provider keeps no copy of what you send or what it returns.

Prepared by BKS Solutions, 19 August 2026, in response to ASTRA's review of the Procurement Platform proposal and to ASTRA's request for a security and compliance position on the underlying AI technology. Technical statements in Part One describe the platform as built and are verifiable during the proof of concept. Compliance statements in Part Two describe certifications held by Amazon, Anthropic and OpenAI, published by those organisations and independently verifiable at the sources listed in Appendix A; they are not BKS certifications and are not presented as such. Commercial figures marked indicative are subject to the commercial schedule.